Module: authentication and accounts

English version of ../../modules/auth.md.

1. Purpose and boundaries

Users, passwords (hashing), JWT (signing and verification), sessions and the session cache. It is isolated from the analytics: it lives in a separate SQLite database. It does not manage permissions on domain data (the API layer decides that) and never stores passwords in clear text.

2. Use scenarios

- Creating a user from the CLI (`python -m backend.users create …`).
- Signing in with a password, issuing a token with a limited lifetime (`ACCESS_TOKEN_EXPIRE_MINUTES`).
- Verifying the token on every request; expiry gives 401.
- Failure: a wrong password and a missing user answer identically and neutrally.

3. Contract

`/auth/*` (login, refresh, logout) — in `backend/openapi.json`. Internal contracts: `backend/auth/service.py` (`AuthService`, `Session`, `AuthorizationRequest`).

4. Data

Owns the SQLite authentication schema (`backend/auth_schema.sql`): users, sessions, keys. PostgreSQL is not used — that makes the module independently testable.

5. Access rules

The module distinguishes "authenticated" from "authorised". Roles and access to analytics are checked in the API layer. The JWT private key is a file from `AUTH_PRIVATE_KEY` with mode 0600.

6. Dependencies

Outgoing: the standard library, `PyJWT[crypto]`. Incoming: `backend/app/main.py`, tests `tests/test_auth.py`.

7. Configuration

`AUTH_DATABASE`, `AUTH_PRIVATE_KEY`, `AUTH_ISSUER`, `AUTH_FRONTEND_LOGIN_URL`, `AUTH_COOKIE_SECURE`, `ACCESS_TOKEN_EXPIRE_MINUTES`. A weak or missing key must break the start rather than degrade into an unsafe mode.

8. Build and debug

```
python -m pytest tests/test_auth.py -q          # without PostgreSQL
python -m backend.users create analyst@example.com
```

9. Tests

`tests/test_auth.py` — user creation, sign-in, token verification and expiry, refusal with wrong credentials. Independence from the analytics is the very ability to run without PostgreSQL.

10. Observability

Failed sign-ins are logged without the password and without the full token. Metrics: the number of 401 responses per route (`/metrics`).

11. Limitations and readiness

- No MFA and no OTP for the web sign-in (OTP exists only in the Telegram scenario).
- The CLI is the only way to create users: no self-service registration by design.
- Readiness: covered by tests that run without the analytics database.